



Limitaciones de visibilidad en red y sistemas

Temas de esta sección:

- Qué significa visibilidad en un SOC
- Por qué no siempre tenemos toda la información
- Limitaciones de red, endpoint, DNS, proxy, SIEM e identidad
- Qué ocurre con tráfico cifrado
- Ausencia de evidencia ≠ ausencia de actividad
- Cómo documentar limitaciones correctamente
- Cierre del módulo

Una de las ideas más importantes para un analista SOC:

No encontrar evidencia no siempre significa que no pasó nada.

Puede significar:

▸ Que realmente no hubo actividad sospechosa.

▸ Que la fuente correcta no está disponible para ese activo.

▸ Que la herramienta no tiene visibilidad sobre ese activo.

▸ Que la actividad no fue registrada por ninguna fuente.

▸ Que los logs no tienen suficiente detalle o retención.

▸ Que la consulta no fue lo suficientemente amplia.

▸ Que la actividad ocurrió fuera del período revisado.

✗ No decir: "Se confirma que no hubo actividad maliciosa."

✓ Mejor: "No se identificó evidencia de actividad maliciosa en las fuentes revisadas durante el período analizado."



Cada herramienta tiene fortalezas y límites. El analista debe conocerlos:

Firewall / Red ✓ IP, puerto, protocolo, acción, volumen ✗ Qué proceso lo generó · Contenido cifrado · Qué ocurrió en el endpoint	EDR ✓ Procesos, comandos, archivos, hashes, conexiones, árbol de procesos ✗ No todos los equipos tienen agente · Agente puede estar desactualizado · Sin visibilidad cloud completa	DNS ✓ Dominios consultados, respuestas, NXDOMAIN, frecuencia ✗ Si la conexión posterior ocurrió · Qué proceso hizo la consulta · Si usó DNS over HTTPS
SIEM ✓ Centraliza y correlaciona múltiples fuentes ✗ Solo analiza lo que recibe · Fuentes no integradas · Logs con retención limitada	Identidad ✓ Logins, MFA, ubicación, dispositivo, cambios de permisos ✗ Geolocalización puede ser imprecisa · MFA exitoso ≠ acceso legítimo · Sesión puede ser robada	Proxy ✓ URLs, categorías, usuario, descargas ✗ No muestra qué proceso lo generó · Sin visibilidad de apps que no usen el proxy

Documentar limitaciones es parte de un análisis profesional. Ejemplos de buena documentación:

✗ Documentación insuficiente:

"No se encontró nada. Caso cerrado."

✓ Documentación correcta (Ejemplo 1):

No se identificó evidencia de descarga o ejecución posterior en las fuentes revisadas. Sin embargo, el endpoint no cuenta con telemetría EDR disponible durante el período analizado, por lo que no es posible confirmar qué proceso generó la conexión observada en firewall.

✓ Documentación correcta (Ejemplo 2):

Se observó consulta DNS hacia dominio sospechoso, pero no se identificó conexión posterior en los logs de proxy disponibles. Se recomienda validar si el host utiliza DNS/HTTPS o si existen fuentes de red adicionales que puedan completar el análisis. El riesgo permanece como pendiente de confirmación.